

ÉTUDE DE CAS

MONDIAL-TICKETS

Implémentation du Système de Management de la Sécurité de l'Information

Conforme à la norme ISO/IEC 27001:2022

Secteur	Effectif	Sites	Norme cible
Billetterie en ligne	~50 collaborateurs	Paris & Berlin	ISO 27001:2022



1. Présentation de la Société

1.1 Contexte & Activité

Mondial-Tickets est une société de 50 collaborateurs fondée en 2005, pionnière dans la vente en ligne de billets pour de grands événements sportifs internationaux. Après avoir géré avec succès la billetterie des Coupes du Monde de football (Allemagne 2006) et de rugby (France 2007), la société s'est imposée comme un acteur référent du secteur.

Son siège social est établi à Paris, avec une filiale opérationnelle à Berlin — deux villes directement liées aux premières compétitions couvertes.

1.2 Ambitions de Croissance & Portefeuille Événements



Portefeuille Événements Cibles

- ▶ Tournoi des 6 Nations de rugby (France & Royaume-Uni)
- ▶ Euro 2024 de football
- ▶ Coupes du Monde de football : 2026 (USA/Canada/Mexique), 2030, 2034
- ▶ Championnat de France de rugby (à partir de 2025)
- ▶ Championnats nationaux de football : France, Allemagne (2025+), autres ligues européennes (2027+)
- ▶ Ouvertures potentielles : agences locales selon opportunités de marché

Mondial-Tickets détient des droits de revente officiels acquis auprès des instances sportives : FIFA, IRB (World Rugby) et FFF. Les billets sont distribués exclusivement via le site www.mondial-tickets.com.

1.3 Indicateurs Clés d'Activité

Indicateur	Valeur
Billets vendus (Coupe du Monde 2010)	~350 000 billets en 2 mois
Valeur moyenne unitaire (grands événements)	150 €
Valeur moyenne unitaire (championnats nationaux)	30 €
Commission Mondial-Tickets	5% du CA billetterie
Objectif grands événements	400 000 billets / 4 ans
Objectif championnats nationaux	600 000 billets / an
CA potentiel annuel (championnats)	~900 000 € de commissions

Incident notable : lors de la Coupe du Monde de rugby 2011 en Nouvelle-Zélande, des défaillances de fiabilité sur la plateforme de vente en ligne ont été constatées en pic de charge. Cet événement a été le déclencheur du projet SMSI.

? Question 1

Quels sont les enjeux stratégiques qui justifient la décision de Mondial-Tickets de s'engager dans une démarche de certification ISO 27001:2022 ?

Identifiez les motivations business, réglementaires et de réputation. Référez les clauses 4.1 et 4.2 de la norme (contexte de l'organisme et parties intéressées).

? Question 2

En vous appuyant sur la clause 4.3 de l'ISO 27001:2022, proposez le périmètre (scope) du SMSI pour Mondial-Tickets.

Précisez les sites, systèmes, processus et actifs inclus/exclus. Justifiez les exclusions éventuelles.

2. Architecture du Système d'Information

2.1 Infrastructure Technique

Le SI de Mondial-Tickets (architecture identique Paris / Berlin) repose sur les composants suivants :

Serveurs & Composants Applicatifs

- Serveur WEB de réservation — exposé sur Internet, point d'entrée clients
- Serveur WEB de paiement — connecté à la gestion comptable, flux sécurisés
- Serveur de base de données Billetterie — données métier critiques
- Serveur Éditique & Courrier — impression et envoi nominatif des billets
- Serveur de Comptabilité — gestion financière (SAGE/MSSQL)
- Serveur de Gestion du Personnel — isolé réseau, non connecté aux autres machines
- Serveur de Messagerie Exchange — communications internes et externes
- Serveur de Sauvegarde HP — sauvegardes hebdomadaires automatisées

2.2 Interconnexions & Partenaires Externes

Partenaire / Réseau externe	Nature des échanges
Ministère de l'Intérieur (FR/DE)	Liste anti-hooligan confidentielle
Partenaire Bancaire	Autorisation de paiement en temps réel
FIFA / IRB / FFF	Disponibilités, prix, conditions de vente
Internet (grand public)	Interface de réservation clients
Filiale Berlin ↔ Paris	Synchronisation base de données billetterie

2.3 Postes Utilisateurs & Mobilité

- PC bureautiques : Windows 10/11, suite Microsoft 365
- Application SAGE : postes comptables et financiers (client lourd)
- Messagerie : Microsoft Outlook (Exchange)
- Portables itinérants : VPN obligatoire, Wi-Fi + Ethernet
- Aucun réseau Wi-Fi déployé sur les sites
- Billets électroniques : impression nominative sécurisée (hologramme, numéro de série non prédictible)

? Question 3

Réalisez une cartographie des actifs informationnels . Pour chaque actif identifié, précisez : type, propriétaire, classification (Public / Interne / Confidentiel / Secret) et valeur pour l'entreprise.

Incluez au minimum : données clients, données bancaires, liste anti-hooligan, billets, base de données billetterie, personnel.

? Question 4

La liste anti-hooligan fournie par le Ministère de l'Intérieur constitue une donnée à traitement particulier. Quelles mesures de sécurité spécifiques préconisez-vous pour cette information ?

Référez les contrôles A.5 (politiques), A.8 (gestion des actifs) et les exigences du RGPD (données sensibles).

3. Organisation & Ressources Humaines

3.1 Structure Organisationnelle — Paris (35 personnes)

Organigramme Siège Paris

P. Aknine — Directeur Général

└─ V. Brugidou — Directrice Informatique (+ R. Zipet, Resp. SMSI)

└─ C. Dufoix — Directrice Ressources Humaines

└─ A. Bouchon — Directeur Financier

└─ C. Laloix — Service Juridique & Contrats

└─ M. Alliot — Correspondant Ministère de l'Intérieur

└─ B. Laporte — Correspondant Fédérations Sportives

3.2 Structure Organisationnelle — Berlin (15 personnes)

Organigramme Filiale Berlin

G. Müller — Directeur de Site / DRH

└─ R. Völler — Responsable Informatique

└─ L. Marchand — Finance & Comptabilité

└─ J. Klinsmann — Service Juridique & Contrats

└─ M. Ballack — Correspondant Ministère Fédéral de l'Intérieur

└─ Service Informatique (6 personnes)

Point critique : il n'existe à ce jour aucun Responsable de la Sécurité des Systèmes d'Information (RSSI) désigné, et aucune politique de sécurité formalisée n'a été adoptée.

? Question 5

La norme ISO 27001:2022 exige un leadership et un engagement fort de la direction (clause 5.1). Comment formaliseriez-vous les rôles et responsabilités en matière de sécurité de l'information chez Mondial-Tickets ? Proposez un RACI pour les fonctions clés du SMSI.

Intégrez notamment : DG, RSSI (à créer), Directrice Informatique, R. Zipet, DSI Berlin, Responsables métier.

? Question 6

La clause 6.1.2 impose une appréciation des risques. Proposez une méthodologie d'analyse de risques adaptée à Mondial-Tickets (ex. ISO 27005). Définissez l'échelle de vraisemblance, l'échelle d'impact et la formule de calcul du risque brut.

Appliquez ensuite votre méthodologie à 3 scénarios de risques réalistes issus du contexte Mondial-Tickets.

4. Processus Métiers & Flux de Données Sensibles

4.1 Processus de Vente en Ligne

L'architecture applicative N-tiers repose sur des composants redondés. Le flux client suit les étapes suivantes :

1. Consultation et sélection des rencontres sportives disponibles
2. Affichage des disponibilités et des prix (synchronisation temps réel avec les fédérations)
3. Gestion du panier d'achat — saisie nominative (nom + numéro de carte d'identité)
4. Contrôle anti-hooligan — vérification sur liste confidentielle du Ministère de l'Intérieur
5. Paiement sécurisé — autorisation bancaire en temps réel
6. Validation et enregistrement de la commande
7. Génération et impression nominative des billets sécurisés
8. Expédition postale sous pli neutre avec accusé de réception

Données Traitées — Criticité Élevée

- Données d'identité spectateurs : nom, prénom, numéro de carte d'identité
- Données bancaires clients : numéro de carte, autorisation de débit
- Liste anti-hooligan (CONFIDENTIELLE) : identités de personnes fichées
- Données de commandes et de facturation
- Billets physiques sécurisés : hologramme, numéro de série non prédictible
- Accusés de réception : conservés 3 mois post-événement

4.2 Plan de Sauvegarde

- Identification des données à sauvegarder (système, config, données, journaux)
- Sauvegardes hebdomadaires automatisées — complètes, incrémentielles, différentielles
- Duplication inter-sites Paris ↔ Berlin
- Tests de restauration et plans de secours
- Test des fonctions de haute disponibilité

? Question 7

Sur la base du flux de vente en ligne, réalisez une analyse des risques pour les 5 actifs les plus critiques. Pour chaque actif : identifiez les menaces, les vulnérabilités, calculez le risque brut, proposez des mesures de traitement et calculez le risque résiduel.

Utilisez l'Annexe A de l'ISO 27001:2022 pour sélectionner les contrôles applicables. Justifiez les exclusions dans la Déclaration d'Applicabilité (SoA).

? Question 8

Le plan de sauvegarde actuel présente des insuffisances. Proposez un plan de sauvegarde conforme aux exigences A.8.13 (sauvegarde de l'information) de l'ISO 27001:2022.

Définissez : fréquences, médias, localisation hors-site, procédures de test, RTO/RPO cibles.

5. Mise en Œuvre du SMSI — ISO 27001:2022

5.1 Cadre du SMSI

La direction de Mondial-Tickets a mandaté R. Zipet comme Responsable Projet SMSI. Le référentiel SMSI actuellement en cours de constitution comprend :

- La politique générale de sécurité de l'information
- La description et justification du périmètre
- L'inventaire des actifs informationnels
- La méthodologie d'appréciation des risques
- L'analyse des risques (dernière version : 2023)
- Le plan de traitement des risques (PTR)
- La Déclaration d'Applicabilité (SoA)

5.2 Domaines Prioritaires Identifiés

Priorités SMSI Issues de l'Analyse de Risques

1. Plan de Continuité d'Activité (PCA/PRA) — risques liés aux pics de charge
2. Protection des données personnelles — identités et données bancaires clients
3. Gestion et traitement des incidents de sécurité
4. Clarification des rôles, postes et responsabilités sécurité
5. Gestion et contrôle documentaire du SMSI

Question 9

Rédigez une Politique de Sécurité de l'Information (PSI) adaptée à Mondial-Tickets, conforme à la clause 5.2 de l'ISO 27001:2022.

La PSI doit couvrir : objectifs, périmètre, engagements de la direction, grands principes (confidentialité, intégrité, disponibilité), obligations des collaborateurs, et modalités de révision.

Question 10

Construisez la Déclaration d'Applicabilité (SoA) pour les domaines thématiques de l'Annexe A de l'ISO 27001:2022 les plus pertinents pour Mondial-Tickets.

Pour chaque contrôle sélectionné : indiquez s'il est applicable, l'état de mise en œuvre (à implémenter / en cours / implémenté), et la justification. Proposez un tableau synthétique.

6. Contrôles de Sécurité & Amélioration Continue

6.1 Contrôles Organisationnels & Techniques

? Question 11

La gestion des accès logiques est un enjeu critique chez Mondial-Tickets. Proposez une politique de gestion des identités et des accès (IAM) conforme aux contrôles A.5.15 à A.5.18 de l'ISO 27001:2022.

Couvrez : principe du moindre privilège, gestion des comptes à privilèges, authentification multi-facteurs, revue périodique des droits, gestion des départs.

? Question 12

Les personnels itinérants utilisent des ordinateurs portables connectés via VPN. Quelles sont les menaces spécifiques ? Proposez un ensemble de mesures conformes à A.6.7 (télétravail) et A.8.1 (terminaux utilisateurs) de l'ISO 27001:2022.

Incluez : chiffrement des postes, politique BYOD, gestion des sessions VPN, contrôle des supports amovibles.

? Question 13

Mondial-Tickets entretient des relations avec plusieurs tiers critiques (banque, Ministère, fédérations sportives, hébergeurs). Proposez un processus de gestion de la sécurité de la chaîne d'approvisionnement conforme aux contrôles A.5.19 à A.5.22.

Définissez : les critères de sélection des fournisseurs, les clauses contractuelles de sécurité, le processus d'audit et de surveillance continue.

6.2 Plan de Continuité & Gestion de Crise

? Question 14

Les défaillances constatées lors de la Coupe du Monde de rugby 2011 révèlent un risque de disponibilité majeur. Élaborez un Plan de Continuité d'Activité (PCA) et un Plan de Reprise d'Activité (PRA) pour le service de vente en ligne.

Définissez : RTO et RPO cibles, scénarios de sinistre couverts (panne serveur, cyberattaque, perte de connectivité), procédures de bascule, organisation de crise, tests.

? Question 15

Un incident de sécurité majeur survient : des billets frauduleux circulent et des données clients semblent avoir été exfiltrées. Décrivez le processus complet de gestion de l'incident conforme à A.5.24 à A.5.28 de l'ISO 27001:2022.

Couvrez : détection et signalement, qualification, confinement, investigation, notification (CNIL/RGPD), correction, retour d'expérience (RETEX).

6.3 Audit, Revue & Amélioration Continue

? Question 16

Préparez un plan d'audit interne du SMSI de Mondial-Tickets conforme à la clause 9.2 de l'ISO 27001:2022.

Définissez : le périmètre des audits, la fréquence, les critères d'audit, la compétence des auditeurs, les modalités de reporting et de suivi des non-conformités.

? Question 17**La clause 9.3 impose une revue de direction annuelle du SMSI. Préparez l'ordre du jour type et les indicateurs clés (KPIs/KRIs) que la direction de Mondial-Tickets devrait examiner.**

Proposez au moins 8 indicateurs mesurables couvrant : incidents, disponibilité, conformité, audits, formation, risques.

? Question 18**Dans le cadre de l'amélioration continue (clause 10 — PDCA), proposez une feuille de route SMSI sur 3 ans pour Mondial-Tickets.**

Structurez la feuille de route en phases (Plan / Do / Check / Act), avec des jalons, des livrables et des critères de succès pour chaque phase. Intégrez les prérequis à la certification ISO 27001:2022.

Annexe — Grille de Correspondance ISO 27001:2022

Tableau de correspondance entre les thématiques de l'étude de cas et les clauses / contrôles de la norme ISO/IEC 27001:2022 :

Q°	Thématique	Clause ISO 27001:2022	Annexe A
Q1	Contexte et enjeux stratégiques	4.1, 4.2	—
Q2	Périmètre du SMSI	4.3	—
Q3	Inventaire des actifs	5.9	A.5.9, A.5.10, A.5.11
Q4	Données sensibles & RGPD	5.9	A.5.12, A.5.13, A.8.10
Q5	Rôles & responsabilités (RACI)	5.1, 5.2, 5.3	A.5.2, A.6.1
Q6	Méthodologie d'analyse de risques	6.1.2, 6.1.3	ISO 27005
Q7	Analyse de risques & SoA	6.1.2, 6.1.3	Annexe A (ensemble)
Q8	Plan de sauvegarde	8.1	A.8.13
Q9	Politique de sécurité	5.2	A.5.1
Q10	Déclaration d'Applicabilité	6.1.3 d)	Annexe A (ensemble)
Q11	Gestion des accès IAM	8.1	A.5.15→A.5.18
Q12	Télétravail & terminaux	8.1	A.6.7, A.8.1
Q13	Sécurité fournisseurs	8.1	A.5.19→A.5.22
Q14	PCA / PRA	8.1	A.5.29, A.5.30
Q15	Gestion des incidents	8.1	A.5.24→A.5.28
Q16	Audit interne	9.2	—
Q17	Revue de direction & KPIs	9.3	—
Q18	Amélioration continue — PDCA	10	—

— Fin du document —